Security Posture Review — before and after hardening

Azure lab: deliberate misconfigurations, detection (Defender for Cloud, Azure Policy, manual review), remediation and prevention. November 2026.

1. Scope and method

Goal. The goal of the audit was to measure how deliberate misconfigurations in a small lab environment affect the Secure Score and the Microsoft cloud security benchmark (MCSB) in Defender for Cloud, and how many of them Defender for Cloud and Azure Policy would detect.

Environment. Pay-as-you-go subscription, a single resource group in the West Europe region. Resources: a Storage account, a Key Vault, a Linux virtual machine (D2 v3) with an NSG, a virtual network and a public IP address, a Log Analytics workspace, and a test user account in Entra ID.

Timeline. Sabotage on 2 Nov 2026, audit and remediation on 3 Nov, post-remediation measurements on 4 Nov and 7 Nov.

Tools. Defender for Cloud free tier (Foundational CSPM), Azure Policy with the ASC Default initiative (MCSB), manual review (IAM, NSG rules, SSH logs via Run command).

Method. The test environment had no resources, so to show how effective the tools are, I first deliberately introduced misconfigurations. Knowing the exact list of errors, I could measure how many of them each tool detected. The work had to be spread over time, because assessments in Defender for Cloud take up to about 24 hours, and in Azure Policy from about fifteen minutes to half an hour. This also let me measure how the deliberate errors affect the Secure Score and MCSB.

Limitations. The results are affected by: the free tier of Defender, the delay in Defender assessments, and the fact that the "after" measurement was taken after the VM had been deleted (for cost reasons), so part of the score increase comes from removing the machine. The lab was small, so individual errors had a large impact on the score; in a large company the same error changes the score by a small percentage. For finding 8 no "before" screenshot was kept. The screenshots were deliberately anonymised (including my public IP address, subscription identifiers and personal data); empty fields in those places result from anonymisation, not from the configuration.

2. Results in numbers

Metric	Before sabotage	After sabotage	After remediation (7 Nov, VM deleted)
Secure Score	100% (D01)	9% (D02)	69% (D24)
MCSB — controls passed	57/63 (D01)	46/63 (D02)	55/63 (D24)
Unhealthy recommendations — total	—	15: 3 High, 9 Medium, 3 Low (D03)	8 (D25)
Unhealthy recommendations — Storage + Key Vault	—	9 (D03)	3 (D25)

Coverage of the 8 introduced errors: Defender 6/8, Azure Policy 7/8, manual review only 1/8 (Owner role).

After remediation: The 3 remaining Storage and Key Vault recommendations did not result from the sabotage: two concern private link (requires a Private Endpoint, i.e. an architecture change), one concerns VNet rules (access from my IP address was kept on purpose). The other 5 concern the subscription (paid Defender plans, number of owners). The intermediate measurement on 4 Nov (Secure Score 42%, D15) shows the Defender delay: the score kept rising over the following days without any configuration changes.

3. Findings

#	Finding	Resource	Severity	Source	Risk ("an attacker could...")	Remediation	Prevention	Evidence
1	Anonymous access to a container	Storage	Medium	Defender + Policy	Anyone on the internet could download the container contents without any authentication.	Storage account → Settings → Configuration → Allow Blob anonymous access = Disabled → Save	Azure Policy, Deny (blocks creation): Storage account public access should be disallowed Azure Policy, Modify (Azure disables it automatically): Configure your Storage account public access to be disallowed	D3, D5 → D10
2	HTTPS not enforced (secure transfer)	Storage	High	Defender + Policy	The Storage account accepted HTTP connections. Someone on the network path, e.g. public Wi-Fi, could read or alter the transferred data and intercept SAS tokens.	Storage account → Settings → Configuration → Secure transfer required = Enabled → Save	Azure Policy, Deny (blocks creation): Secure transfer to storage accounts should be enabled Azure Policy, Modify (Azure enables it automatically): Configure secure transfer of data on a storage account	D3 → D14
3	Network access from all networks	Storage	Medium	Defender + Policy	The Storage account was reachable from the entire internet. Anyone who obtained a key or token, or found a public container, could access the data from anywhere.	Storage account → Security + networking → Networking → Manage → Enable → Enabled from selected networks. Then Virtual networks, IP addresses, and exceptions → View → added my public IP address → Save	Azure Policy, Deny (blocks creation): Storage accounts should restrict network access IaC templates with restricted network access	D3 → D21, D14
4	No logs (Diagnostic Settings)	Key Vault	Low	Defender + Policy	Secret reads were not recorded. Unauthorised use of a secret would not be detected, and after an incident it would be impossible to establish who read it and when.	Key Vault → Monitoring → Diagnostic settings → + Add diagnostic setting → audit logs selected → Send to Log Analytics workspace → Save	Azure Policy, DeployIfNotExists (Azure adds the logs automatically): Deploy - Configure diagnostic settings for Azure Key Vault to Log Analytics workspace	D3, D17, D18 → D20
5	No purge protection	Key Vault	Medium	Defender + Policy	A user with permissions (an insider or a compromised account) could delete the Key Vault and purge it immediately. Secrets and keys would be lost permanently.	Key Vault → Settings → Properties → Enable purge protection → Save	Azure Policy, Deny (blocks creation): Key vaults should have deletion protection enabled	D3, D17 → D19
6	Key Vault accessible from all networks	Key Vault	Medium	Defender + Policy	If someone obtains the credentials or a sign-in token of an account with access, and there is no restriction on the networks it can be used from, they can use the vault from anywhere on the internet.	Key Vault → Settings → Networking → Firewalls and virtual networks → Allow public access from specific virtual networks and IP addresses → added my public IP address → Apply	Azure Policy, Deny (blocks creation): Azure Key Vault should have firewall enabled or public network access disabled Azure Policy, Modify (Azure enables the firewall	D3, D17 → D19

#	Finding	Resource	Severity	Source	Risk ("an attacker could…")	Remediation	Prevention	Evidence
							automatically): Configure key vaults to enable firewall	
7	SSH (22) open to the entire internet	VM	High (own assessment)	Policy only	SSH gives remote shell access to the machine. Port 22 was open to the entire internet, so after a successful login an attacker could silently delete or alter data or upload malware. 19 failed login attempts from 14 IP addresses were recorded within about 4 hours.	VM → Networking → Network settings → SSH rule → Source = IP Addresses → Source IP addresses/CIDR ranges = my public IP address → Save	A custom Azure Policy rule with Deny, or closing the port and connecting another way (JIT VM access)	D16, D4, D6–D8 → D11
8	Owner with the right to assign all roles for a developer	RG (IAM)	High (own assessment)	Manual review only	The developer, or anyone who compromises their account, would have full control over the RG: they could delete resources, grant themselves access to Key Vault secrets or assign Owner to another account, creating a persistent backdoor.	Resource group → Access control (IAM) → Role assignments → testdev (Owner) → Delete. Then + Add → Add role assignment → Reader → Members → testdev → Review + assign	Least privilege and access reviews Activity Log alert (Create role assignment) — detection	own notes → D12

Severity 1–6: Defender for Cloud. Severity 7–8: own assessment (likelihood × impact). For finding 8 the "before" screenshot (Owner role with the "all roles" option) was not kept.

4. Conclusions

What did Defender not detect, and why?

Defender detected 6 of the 8 errors. It did not detect SSH open to the internet or the Owner role for the developer account. The open SSH port was detected only by Policy (D16), even though the rule belongs to the same ASC Default initiative — Defender does not show every Policy result as a recommendation. Defender only checks the number of subscription owners, not whether a specific person should be an owner. That is an organisational decision, and any excessive Owner assignment should be verified manually in IAM. As a complement, an alert can be set on the "Create role assignment" event in the Activity Log (detection). No recommendation does not mean no problem: both sources, Defender for Cloud and Azure Policy, need to be compared, and a manual review performed. The tool sees the configuration, not the business context of the organisation.

What would Policy have blocked from the start if it had been assigned before the sabotage?

ASC Default was assigned before the sabotage, but its rules use the Audit effect, so we only see what is Non-compliant. Microsoft does not set rules to Deny by default, because every environment is different and whether something should be blocked depends on the customer's individual needs. With the Deny effect it would not have been possible to create the misconfigured resources in findings 1, 2, 3, 5 and 6. For finding 4 there is no Deny, but DeployIfNotExists would have added the logs automatically — the error would have been fixed automatically, though not blocked. For finding 7 the built-in rule only audits; SSH would only be blocked by a custom rule with Deny or by prohibiting public IPs on VMs. For finding 8 Policy does not help, because permissions have to be verified manually. In summary: Policy with Deny would have blocked 5 of the 8 errors, and with DeployIfNotExists 6 of 8 would have been blocked or fixed automatically. The effectiveness of Deny was confirmed by a test with the Allowed locations rule — creating a resource in a disallowed region was blocked already in the form (D13).

How many SSH login attempts came in, and what does that say about open ports?

19 failed attempts from 14 unique IP addresses in about 4 hours (D06, D07). Two addresses accounted for most entries, 8 each (D08). The VM was not used over SSH, so all attempts came from outside. Nobody was looking for this particular machine — these are automated scanners that sweep the entire internet for targets. The attacks were stopped by key-based login (a compensating control), not by a closed port. An open port 22 gets attacked within a few hours, and key-based login is not enough: a key can leak, and a vulnerability in SSH itself can bypass login. Port 22 should not be exposed to the internet; access should go through JIT VM access.

5. Recommendations

If I were responsible for the security of a real company in Azure, based on this lab I would implement:

1. **Azure Policy rules with the Deny effect** assigned at subscription or management group level — thanks to inheritance they protect all lower-level resources, including those created in the future. Rolled out in stages: Audit first, then Deny.
2. **Resource creation templates** — standardised, to avoid human error.
3. **RBAC:** the principle of least privilege and regular access reviews, complemented by an alert on the "Create role assignment" event in the Activity Log (detection) to catch administrative role assignments.
4. **Restricting network access:** deny by default, with access only from specified networks or addresses.
5. **Management ports (SSH/RDP):** exposing them to the internet is asking for trouble. The port should be closed by default and opened only on request, for a specific IP address and for a limited time (JIT VM access in Defender for Servers Plan 2).
6. **Key Vault:** diagnostic logs and purge protection enabled. In a business-critical company (e.g. a supplier to hospitals), losing the keys could halt production, with consequences going beyond financial losses.

Appendix — list of evidence

#	What it shows
D01	Secure Score 100%, MCSB 57/63 — before sabotage
D02	Secure Score 9%, MCSB 46/63 — after sabotage
D03	Defender recommendations export after sabotage (not published — contains identifiers)
D04	NSG rule: SSH (22), source Any
D05	File in the container accessible without signing in
D06	Run command: 19 failed SSH login attempts
D07	Run command: 14 unique IP addresses
D08	Run command: IP addresses with number of attempts
D10	The same file after remediation: PublicAccessNotPermitted
D11	NSG rule after remediation: SSH only from my IP address
D12	Resource group IAM after remediation: test account with the Reader role
D13	Allowed locations (Deny): region outside the list blocked in the form
D14	Recommendations export, 4 Nov (not published)
D15	Secure Score 42% — intermediate measurement, 4 Nov
D16	Policy: Management ports should be closed — Non-compliant
D17	Policy: Key Vault — 4 non-compliant rules before remediation
D18	Key Vault: no Diagnostic Settings
D19	Policy: Key Vault — 2 non-compliant rules after remediation
D20	Policy: Resource logs in Key Vault — Compliant after remediation
D21	Policy: Storage — 2 remaining rules after remediation
D24	Secure Score 69%, MCSB 55/63 — 7 Nov
D25	Recommendations export, 7 Nov (not published)